

ชุดโปรแกรมตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

นายปริวรรต ผ่องแผ้ว

นายภูมินทร์ ตันตสถิตยานนท์

นายอริศ วรสวัสดิ์

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2549

ชุดโปรแกรมตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

นายปวิวรรต ผ่องแผ้ว
นายภูมินทร์ ตันตสธิตยานนท์
นายอชิศ วรสวัสดิ์

อาจารย์ที่ปรึกษา

อ.อัศรเดช วัชรภูพงษ์
ผศ.ธนา หงษ์สุวรรณ
อ.ธนัญชัย ตรีภาค

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2549

ปริญญานิพนธ์ปีการศึกษา 2549

ภาควิชา วิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

เรื่อง ชุดโปรแกรมตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

ผู้จัดทำ

- | | | |
|-------------------------------|--------------|----------|
| 1. นายปวิรรต ผ่องแผ้ว | รหัสประจำตัว | 46010430 |
| 2. นายภูมินทร์ ตันทสถิตยานนท์ | รหัสประจำตัว | 45010588 |
| 3. นายอริศ วรสวัสดิ์ | รหัสประจำตัว | 46010907 |

อาจารย์ที่ปรึกษา

(อาจารย์อัครเดช วัชรภูพงษ์)

อาจารย์ที่ปรึกษา

(ผู้ช่วยศาสตราจารย์ธนา หงษ์สุวรรณ)

อาจารย์ที่ปรึกษา

(อาจารย์ธัญชัย ตรีภาค)

ระบบตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

นายปวิรรต ผ่องแผ้ว	46010430
นายภูมินทร์ ตันทสติดิยานนท์	46010588
นายอริศ วรสวัสดิ์	46010907
อาจารย์อัครเดช วัชรภูพวงษ์	อาจารย์ที่ปรึกษา
ผศ.ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษาร่วม
อาจารย์ธนัญชัย ตริภาค	อาจารย์ที่ปรึกษาร่วม
ปีการศึกษา 2549	

บทคัดย่อ

ถึงแม้ระบบรักษาความปลอดภัยทางคอมพิวเตอร์จะดีเลิศเพียงใด ก็ยังมีโอกาสเกิดการละเมิดได้ ฉะนั้นระบบรักษาความปลอดภัยทางคอมพิวเตอร์ที่ดีจึงต้องเตรียมความพร้อมต่อเหตุการณ์ดังกล่าว ทั้งก่อนหน้า ระหว่าง และหลังเกิดการละเมิดความปลอดภัย เพื่อทราบได้ว่าเกิดการละเมิดขึ้นแล้ว การทำอะไรไปบ้าง กระทบต่อสิ่งใดบ้าง และจะทำการกู้คืนระบบให้สามารถทำงานเช่นเดิมได้อย่างไร รวมถึงการรวบรวมหลักฐานเพื่อเอาผิดต่อผู้ละเมิดความปลอดภัย

โครงการนี้เป็นโครงการใหม่ที่มุ่งศึกษาแนวทางการตอบสนองเมื่อเกิดการละเมิดความปลอดภัยในทุกช่วงเหตุการณ์ โดยเน้นระบบปฏิบัติการยูนิกซ์

INCIDENT RESPONSE SYSTEM

Mr. Parivat Pongbhaesaj	45010450
Mr. Phumin Tantasatityanont	45010588
Mr. Athit Worasawad	46010907
Mr. Akkradach Watcharapupong	Advisor
Asst. Prof. Thana Hongsuwan	Co-Advisor
Mr. Tanunchai Tripak	Co-Advisor
Academic Year 2006	

ABSTRACT

Even though the computer security system is now much more powerful than the old days. It cannot be considered the perfect system anyway. Since the problems still exist, the reliable security system has to be ready for the unexpected events to occur. The system should be able to handle those at the time intrusion taking place as well as before and after the affairs in order to be able to make an incident response to such an event. The incident response mentioned includes knowing what the intruder has done to the system, detecting the effects to the system, recovering the system and gathering the information due to the legal issue.

This project purposes presenting a new method in computer security aiming at the effective way to response when there is an intrusion. All is done under UNIX environment.

กิตติกรรมประกาศ

ปริญญานิพนธ์ฉบับนี้จะไม่สามารถเสร็จสมบูรณ์ได้ถ้าไม่ได้รับคำแนะนำ คำเตือน
ทั้งหลายจากอาจารย์อัครเดช วัชรภูพงษ์ ผู้ช่วยศาสตราจารย์ธนา หงษ์สุวรรณ และอาจารย์ธัญชัย
ตรีภาค คณะผู้จัดทำขอขอบพระคุณอย่างยิ่งสำหรับทุกสิ่งทุกอย่างที่ได้รับจากท่านทั้งสาม

นอกจากนี้ขอขอบคุณสถาบัน ภาควิชาวิศวกรรมคอมพิวเตอร์ และห้องวิจัยและพัฒนาการ
รักษาความปลอดภัยข้อมูล (ISAG) ที่ได้เอื้อเฟื้อสถานที่ให้คณะผู้จัดทำได้ทำการวิจัยและศึกษา
ขอขอบคุณเพื่อนๆ พี่ ๆ ห้อง ISAG ที่ได้ให้คำแนะนำและให้ความช่วยเหลือในยามที่ผู้จัดทำพบกับ
ปัญหาได้ดีเสมอมา

สุดท้ายต้องขอขอบคุณบิดา มารดาที่ได้ให้กำเนิด คอยสั่งสอน ให้การสนับสนุนการศึกษา
และเป็นกำลังใจในการศึกษาเล่าเรียนเสมอ นับเป็นพระคุณอย่างยิ่ง

นายปวิวรรต ผ่องเกสัช

นายภูมินทร์ ตันทสถิตยานนท์

นายอิศ วรสาสดี

สารบัญ

	หน้า
บทคัดย่อภาษาไทย	I
บทคัดย่อภาษาอังกฤษ	II
กิตติกรรมประกาศ	III
สารบัญ	IV
สารบัญตาราง	VII
สารบัญภาพ	VIII
บทที่ 1 บทนำ	1
1.1 บทนำ	1
1.2 วัตถุประสงค์ของโครงการ	1
1.3 ประโยชน์ที่คาดว่าจะได้รับ	1
1.4 ขอบเขตของโครงการ	2
1.5 เนื้อหาของรายงาน	2
บทที่ 2 ทฤษฎีที่เกี่ยวข้อง	3
2.1 บทนำ	3
2.2 ทฤษฎีการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย	3
2.3 รูปแบบและพฤติกรรมของผู้บุกรุก	11
2.4 ระบบตรวจจับผู้บุกรุก	12
2.4.1 ระบบตรวจจับผู้บุกรุกที่โฮสต์	13
2.4.1.1 Unix logs (syslogd)	14
2.4.1.2 syslog-ng	20
2.4.1.3 Tripwire	21
2.4.2 ระบบตรวจจับผู้บุกรุกทางเครือข่าย	22
2.4.2.1 Snort และ Snort-Inline	23
2.5 Internet Protocol Security (IPSec)	24

สารบัญ(ต่อ)

หน้า

2.6 การตรวจร่องรอยหลักฐาน	27
2.6.1 การตรวจร่องรอยหลักฐานทางคอมพิวเตอร์	27
2.6.1.1 พื้นฐานสำคัญที่ใช้ในการ ตรวจสอบการละเมิดสิทธิ์ และหาข้อมูล	27
2.6.2 การตรวจร่องรอยหลักฐานทางเครือข่าย	31
2.7 การป้องกันบัพเฟอร์โอเวอร์โฟลว์	34
2.8 การดักการเรียกใช้ฟังก์ชันในระบบปฏิบัติการลินุกซ์	37
2.8.1 การดักการเรียกไลบรารี โดยใช้ LD_PRELOAD	37
2.8.2 การเขียนโดยใช้ เคอร์เนล โมดูล โดยใช้ sys_call_table	38
2.9 การเขียนโปรแกรมเพื่อสร้างเคอร์เนล โมดูลในลินุกซ์	38
2.9.1 รูปแบบการเขียนเคอร์เนล โมดูล	38
2.9.2 การคอมไพล์เคอร์เนล โมดูล	39
2.9.3 การผ่านค่าตัวแปรเข้าไปใน โมดูลผ่านทางคอมมานด์ไลน์	39
2.9.4 ข้อแตกต่างระหว่างโปรแกรมกับโมดูล	40
2.9.5 ซิสเต็มคอล	40
2.9.6 ระบบไฟล์ /proc	41
2.10 บัพเฟอร์โอเวอร์โฟลว์	41
2.10.1 การจัดการหน่วยความจำ	42
2.10.2 การเรียกฟังก์ชัน	43
2.10.3 บัพเฟอร์และส่วนที่เสี่ยงต่อการถูกโจมตี	44
2.10.4 การล้นของบัพเฟอร์	45
2.10.5 หลักการของสแต็กโอเวอร์โฟลว์	46
2.10.6 การล้นของฮีป	49
บทที่ 3 การออกแบบและพัฒนา	50
3.1 บทนำ	50
3.2 การออกแบบฮาร์ดแวร์	50
3.3 การออกแบบซอฟต์แวร์	51
3.3.1 ระบบป้องกันผู้บุกรุกทางเครือข่าย	51

สารบัญ(ต่อ)

หน้า

3.3.2 ระบบตรวจจับและป้องกันผู้บุกรุกทางคอมพิวเตอร์	51
3.3.3 การกู้คืนระบบ	56
บทที่ 4 การทดสอบและผลการทดสอบ	58
4.1 บทนำ	58
4.2 การทดสอบที่ 1 ทดสอบระบบป้องกันผู้บุกรุกทางเครือข่าย	58
4.3 การทดสอบที่ 2 ทดสอบระบบตรวจจับผู้บุกรุก	60
4.4 การทดสอบที่ 3 ทดสอบการกู้คืนระบบ	61
บทที่ 5 บทสรุป	64
5.1 วิเคราะห์และสรุปผลการทดสอบ	64
5.2 ปัญหาและอุปสรรค	64
5.3 แนวทางการประยุกต์และการพัฒนา	65
บรรณานุกรม	66
ภาคผนวก	67
ภาคผนวก ก. คู่มือการใช้งาน	67

สารบัญตาราง

ตารางที่	หน้า
2.1 แสดงค่า facility และความหมาย	14
2.2 แสดงค่า priority และความหมาย	15
2.3 แสดงรายชื่อซอฟต์แวร์ที่ใช้ syslog	18

สารบัญรูปภาพ

รูปที่	หน้า
รูปที่ 2.1 ขั้นตอนการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย	4
รูปที่ 2.2 แสดงตัวอย่างการหา checksum	22
รูปที่ 2.3 รูปแบบการใช้งาน IPsec	25
รูปที่ 2.4 Authentication Header	26
รูปที่ 2.5 Encapsulated Security Payload	26
รูปที่ 2.6 รูปแสดงปฏิกิริยาการตอบสนองระหว่าง Linux kernel กับ โมดูล DSM	36
รูปที่ 2.7 ส่วนต่างๆของ memory	41
รูปที่ 2.8 แสดง buffer ใน memory	43
รูปที่ 2.9 แสดงการเกิด buffer overflow	44
รูปที่ 2.10 แสดงวิธีการโจมตีแบบ stack overflow	47
รูปที่ 3.1 แผนผังการออกแบบ	49
รูปที่ 3.2 การทำงานของ snort	50
รูปที่ 3.3 การทำงานของ kernel Module	55
รูปที่ 4.1 แสดงการสแกนพอร์ตเพื่อหาช่องโหว่	57
รูปที่ 4.2 ขึ้นเตือนว่ามีการทำสแกนพอร์ต	58
รูปที่ 4.3 กำลังบุกรุกผ่านโปรแกรม Snort	58
รูปที่ 4.4 ระบบขึ้นเตือนและสามารถป้องกันได้	58
รูปที่ 4.5 พยายามทำการยกระดับสิทธิ์ของตนเองโดยใช้ exploit code	59
รูปที่ 4.6 ระบบสามารถตรวจสอบการบุกรุกได้	59
รูปที่ 4.7 kernel สามารถตรวจจับได้เมื่อมีการเขียนทับ file	60
รูปที่ 4.8 ใช้โปรแกรมสำหรับเช็ก file integrity	60
รูปที่ 4.9 การทำ snapshot	61
รูปที่ 4.10 file ที่ได้ทำการ snapshot	61
รูปที่ 4.11 ทำการเลือก file ที่ทำการ restore	62
รูปที่ 4.12 ทำการ restore เสร็จสมบูรณ์	62
รูปที่ ก.1 หน้าล็อกอินเข้าระบบ	65
รูปที่ ก.2 หน้า Home ของระบบ	66
รูปที่ ก.3 หน้าเช็กความถูกต้องของไฟล์	67
รูปที่ ก.4 ส่วนเช็กและเพิ่มส่วนที่ต้องการ	67

รูปที่ ก.5 ค้นหาในส่วนเชกความถูกต้องของไฟล์	68
รูปที่ ก.6 ผลของการตรวจสอบความถูกต้องของไฟล์	68
รูปที่ ก.7 รายละเอียดของไฟล์	69
รูปที่ ก.8 ค้นหาข้อมูลทางเครือข่าย	70
รูปที่ ก.9 ผลการหาข้อมูลทางเครือข่าย	71
รูปที่ ก.10 รายละเอียดของแพ็กเก็ต	72
รูปที่ ก.11 ค้นหาชื่อไฟล์ของระบบ	73
รูปที่ ก.12 ผลการหาชื่อไฟล์ของระบบ	73
รูปที่ ก.13 หาผู้ใช้งานในระบบ	74
รูปที่ ก.14 ผลการหาผู้ใช้งานในระบบ	74
รูปที่ ก.15 ส่วนค้นหาว่าโดนทำ exploit เมื่อไร	75
รูปที่ ก.16 ผลการค้นหาว่าโดน exploit	75
รูปที่ ก.17 การทำ recovery	76
รูปที่ ก.18 การตั้งค่า	77